

ICT2212

Ethical Hacking



Hardening a Server System

Dr Guo Huaqun (Linda)

Hardening a server system

- **Keep Software Updated**

- Regularly apply security updates and patches to the operating system, applications, web server software (e.g., Apache, Nginx), and any web applications you run.
- Regularly update the database management system (DBMS) software (e.g., MySQL, PostgreSQL, MongoDB) to apply security patches and updates.
- Use the latest versions to benefit from security patches and bug fixes.
- Set up automatic updates where possible.

- **Security Updates**

- Implement a process to track and apply security updates promptly.
- Stay informed about vulnerabilities and security advisories related to your software and services.

Hardening a server system

- **Minimal Installation & Minimize Attack Surface**

- Start with a minimal installation of the operating system. Only install the necessary packages and services.
- Remove or disable unnecessary services and daemons that are not required for your server's function.
- Install only the necessary software and components. Remove or disable unused modules and plugins.
- Disable directory listing to prevent information leakage.

Hardening a server system

- **Firewall Configuration**

- Use/implement a firewall (e.g., ufw (Uncomplicated Firewall), iptables, firewalld) to restrict incoming and outgoing network traffic.
- Only allow necessary ports and services.
- Implement a default-deny rule to block all unnecessary traffic.
- **For Database Server**
- Use a firewall to restrict incoming and outgoing network traffic to the database server.
- Isolate the database server from public networks if possible.
- Encrypt network traffic using SSL/TLS for secure data transfer.

Hardening a server system

- **Access Control**

- Implement strong authentication mechanisms, such as SSH key-based authentication.
- Limit SSH access to specific users or groups.
- Disable root login via SSH.
- Use password policies (e.g., strong passwords, password expiration) and account lockout policies.
- Restrict access to sensitive directories and files using proper file system permissions.
- Implement access control lists (ACLs) if needed.
- Use web application firewalls (WAFs) to protect against common web attacks
- **For Database server**
- Use strong authentication mechanisms for database access.
- Implement role-based access control (RBAC) to restrict access based on user roles and privileges.
- Avoid using the root or superuser account for routine database operations.
- Enforce password policies, including strong password requirements and regular password changes.

Hardening a server system

- **Strong Authentication**

- Implement strong authentication mechanisms, such as SSH key-based authentication.
- Limit SSH access to specific users or groups.
- Use SSH key-based authentication for remote administration.
- Disable password-based SSH login and the root account for SSH access.

- **SSL/TLS Encryption**

- Enable SSL/TLS encryption to secure data in transit.
- Use strong encryption protocols and cipher suites.
- Obtain an SSL/TLS certificate from a trusted certificate authority (CA).

Hardening a server system

- **Database Encryption**

- Implement data encryption at rest to protect data stored on disk.
- Consider using Transparent Data Encryption (TDE) or file-level encryption provided by the DBMS.
- Disable password-based SSH login and the root account for SSH access.

- **Data Classification and Segmentation**

- Classify data based on sensitivity and implement segmentation to isolate sensitive data from less critical data.

Hardening a server system

- **SQL Injection Prevention**

- Use parameterized queries and prepared statements to prevent SQL injection attacks.
- Input validation and output encoding should be applied to user-generated data.

- **Minimum Necessary Privileges**

- Limit user privileges to only what is required for their tasks.
- Use database roles and permissions to grant the minimum necessary privileges.
- Avoid granting excessive privileges to avoid the risk of privilege escalation.

Hardening a server system

- **File Upload Security**

- If your web application allows file uploads, validate and sanitize user input.
- Store uploaded files in a secure location, and restrict file execution if necessary.

- **Rate Limiting and DDoS Protection**

- Implement rate limiting to protect against brute-force attacks.
 - Login only allows 5 attempts with 2 mins.
- Consider using DDoS protection services or appliances to mitigate distributed denial-of-service attacks.

Hardening a server system

- **File System Security**

- Implement file system permissions and ownership to restrict access to sensitive files and directories.
- Use the principle of least privilege when assigning permissions.
- Enable file system auditing to monitor changes.

- **Network Security**

- Disable unnecessary network services.
- Use intrusion detection and prevention systems (IDS/IPS) to monitor and block suspicious network activity.
- Segment your network to isolate critical systems.

Hardening a server system

- **Logging and Monitoring**

- Configure / Implement centralized logging to monitor system and application logs for real-time threat detection.
- Enable logging of web server access and error logs.
- Regularly review and analyze logs for signs of suspicious or unauthorized activities.
- Set up alerting for critical events / unusual activities.
- **For Database Server**
 - Enable auditing and logging features provided by the DBMS to track database activities.
 - Store logs securely and regularly review them for suspicious activities.
 - Implement real-time monitoring and alerting for critical database events.
 - Consider using security tools and database security scanners to assess and monitor the security of your database server.

Hardening a server system

- **Application Security**
 - Secure web applications by using secure coding practices and web application firewalls (WAFs).
 - Regularly scan and test your applications for vulnerabilities.
 - Isolate applications using containers or virtualization.
- **Backup and Recovery**
 - Implement regular automated backups of your data and configuration settings.
 - Store backups off-site and test the restore process.
 - Consider disaster recovery and business continuity planning.
 - **For Database Server**
 - Implement regular database backups, including full and incremental backups.
 - Store backups securely and test the restore process regularly.
 - Ensure that backup data is also encrypted and protected.

Hardening a server system

- **Security Headers**
 - Implement security headers in your web server configuration to protect against various web vulnerabilities. Common security headers include HTTP Strict Transport Security (HSTS), Content Security Policy (CSP), and X-Content-Type-Options.
- **Web Application Security**
 - Secure your web applications by following secure coding practices.
 - Regularly scan and test for vulnerabilities (e.g., using tools like OWASP ZAP or Nessus).
 - Keep software libraries and frameworks updated.

Hardening a server system

- **Security Policies and Documentation**

- Develop and maintain security policies and procedures for your server environment.
- Document configurations, access controls, and security measures, including database.
- Educate your team and users about security best practices.

- **Physical Security**

- Secure physical access to your server hardware and data center.
- Implement environmental controls (e.g., temperature, humidity) to protect server hardware.

Hardening a server system

- **Incident Response Plan**
 - Develop an incident response plan to handle security incidents and breaches.
 - Clearly define roles, responsibilities, and communication procedures.
 - Test the plan through tabletop exercises.
 - Practice and update the plan regularly.
 - Develop an incident response plan specific to database security incidents.
 - Define procedures for investigating and responding to data breaches or unauthorized access.
- **Regular Security Audits and Penetration Testing**
 - Conduct regular security audits, vulnerability assessments, and penetration testing.
 - Conduct regular security audits, vulnerability assessments, and penetration testing of your database server to identify and address vulnerabilities.
 - Engage third-party security experts if needed to identify vulnerabilities and weaknesses.
 - Enable auditing features in the DBMS to track changes to database objects and data.
 - Regularly review and analyze audit logs for unauthorized access or changes.

Hardening a server system

- **Database Hardening Guides**
 - Consult official hardening guides provided by the DBMS vendor or community resources specific to your database technology.
- **Backup Encryption and Rotation**
 - Encrypt database backups and ensure they are regularly rotated.
 - Store backup encryption keys securely.
- **Authentication and Authorization**
 - Utilize two-factor authentication (2FA) for administrative access to the database server.
 - Implement database-level authorization controls in addition to the operating system-level controls.

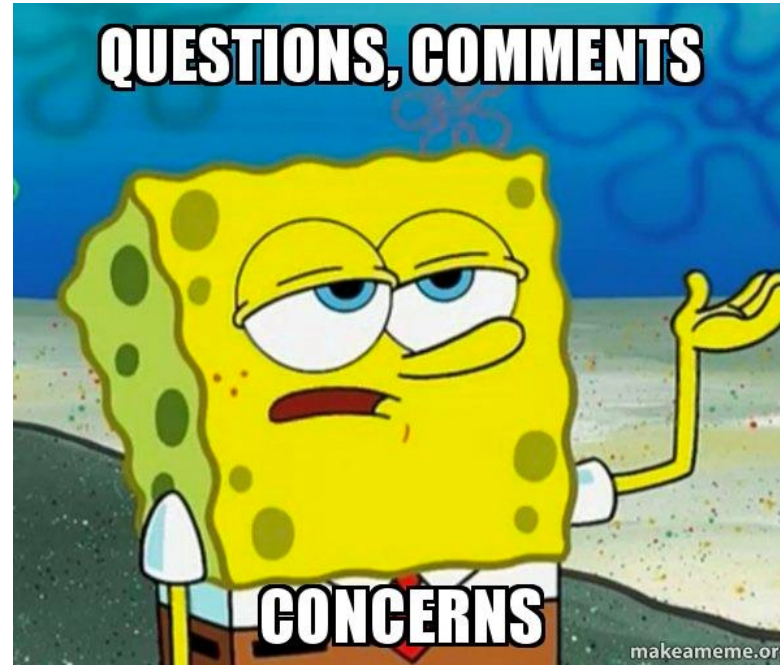
Hardening a server system

- **Compliance and Regulations**

- Ensure compliance with relevant security regulations and industry standards (e.g., GDPR, HIPAA, PCI DSS).
- Keep records and audit trails as required by regulations.

- **User Training**

- Train your team and users on security awareness and best practices.
- Encourage reporting of security incidents and suspicious activities.
- Train your development and operations teams on web security best practices.
- Educate users and administrators about security awareness and reporting procedures.
- Provide training to database administrators and users on database security best practices



QUESTIONS OR COMMENTS?